PHP發生了什麼？

01 / 概覽 | PHP2Shell：支撐網站運作的PHP本身出現問題

登入前也可能遭到攻擊
2026年10月21日，PHP開發團隊發布了兩項嚴重漏洞的修復版本。條件滿足時，未經身分驗證的攻擊者可能在伺服器上執行非法程式碼。

什麼是PHP？
WordPress等系統使用的伺服器端程式語言，負責產生頁面和處理輸入內容。

CVE-2026-109618
記憶體不足時的處理可能使內部資料處於不完整狀態，非法記憶體操作可能導致程式碼執行。

CVE-2026-109619
與已釋放記憶體有關的舊內部狀態可能殘留，並在後續請求中被使用，從而可能導致程式碼執行。

兩項嚴重性評分均為9.2 / 10
按CVSS v4.0屬於「嚴重」。實際攻擊是否成功也取決於架構和設定。

僅加強管理後台密碼無法從根本上防禦。
TODOROKI / 網路安全 / 2026.10.23

有哪些危險？

02 / 風險 | 損害範圍取決於PHP的權限及可存取的資訊

01 資訊外洩
伺服器設定、身分憑證以及可連接資料庫中的資訊等可能被竊取。

02 網站遭到竄改
頁面或連結被改寫、設置虛假輸入頁面等，也可能使損害波及使用者。

03 服務停止及入侵長期化
干擾處理或植入惡意檔案可能造成營業中斷或再次入侵。

不只是WordPress
PHP官方廣泛提醒處理網路請求的PHP環境注意，包括PHP-FPM、Apache的mod_php、php-cgi、FrankenPHP、LiteSpeed等。

尤其是mod_php，已有在應用程式碼運作前攻擊便能成功的示範案例。僅設置登入頁面並不能放心。

這裡列出的是可能的損害，並不意味著所有網站都已被入侵。
TODOROKI / 網路安全 / 2026.10.23

根本對策是更新PHP本身

03 / 更新 | 與WordPress本體及外掛更新分開確認

包含本次修復的版本
PHP 8.2：8.2.35
PHP 8.3：8.3.36
PHP 8.4：8.4.27
PHP 8.5：8.5.12

使用同系列上述修復版及之後的版本，或使用發行方已套用本次修復的套件。不要只憑顯示的版本判斷，也要查看提供方公告。

確認 → 保全 → 更新 → 檢查
1. 在伺服器控制面板或向簽約服務商確認是否使用PHP及修復狀況。
2. 備份檔案和資料庫，確認相容性。
3. 更新PHP，重新啟動必要程序，檢查有無遺漏更新。
4. 檢查頁面顯示、登入行為以及可疑檔案和通訊。

PHP 8.1及更早版本的常規支援已經結束。應向發行方確認修復供應情況，並推進遷移到仍受支援的系列。

租用伺服器應確認：「本次兩個CVE是否已經處理？」
TODOROKI / 網路安全 / 2026.10.23

無法更新時怎麼辦？

04 / 行動 | 應急措施、入侵後處理及一般使用者可做之事

不要僅憑應急措施判斷「安全」
官方有可減少部分攻擊路徑的設定變更，但徹底解決只能靠更新。應與管理員商量，並考慮限制存取或暫時停止相關服務。

不要照抄設定值
停用上傳進度功能等只是針對特定路徑的緩解措施。調整記憶體限制也可能影響可用性，須結合整體環境判斷。

懷疑已遭入侵，不能更新後就結束
修復版本不會自動刪除已經植入的惡意檔案。應保全日誌等證據，調查入侵範圍；必要時從安全環境復原並更換身分憑證。

一般使用者應查看官方指引
對方伺服器由營運方修復。應查看服務警示，在不自然的登入或付款頁面停止輸入。按公告辦理手續時，應透過官方應用程式或已知的官方網站進入。

僅僅「顯示正常」並不能判斷安全性。
TODOROKI / 網路安全 / 2026.10.23